

Procédure d'implémentation

Certify Management Hub — OPT-RP-01.optimedit.eu

Architecture hybride (PKI Publique & Entreprise ADCS)

TLS bridging : certificat public SAN (DNS-01 / OVH) sur le Revers-Proxy, certificat ADCS interne sur les 6 backends

Connexion sécurisée est déchiffrée à l'entrée du proxy, puis rechiffrée avant d'être envoyée vers le serveur web backends

Note de révision (v4)

Ce document corrige et complète la procédure initiale. Points révisés :

- 1) le périmètre du certificat public : les 6 backends OPT-IIS-01..06 sont RETIRÉS du SAN public — ils gardent leur certificat interne ADCS existant, déployé par Ansible. Le certificat public LE ne couvre plus que OPT-RP-01 + les 13 sous-domaines applicatifs ;
- 2) ajout d'une Phase 6 dédiée à l'architecture « TLS bridging » (**cohabitation des deux PKI**) et à son intérêt en matière de Certificate Transparency.

Architecture des sites

Structure	Exemple	Avantages	Inconvénient	Choix du projet
Sous-domaines 13 sous domaines (13 Sites)	direction, rh, compta	Sécurité et Isolation Supervision et Traçabilité Granulaires Maîtrise de la PKI Interne (ADCS) & Automatisation Évolutivité et Flexibilité Métier	Administration lourde	X
Sous-dossiers 13 Sous-dossiers (1 site)	/sites/direction, /sites/rh, /sites/compta	Administration centralisée et facile sur un seul site	Moins sécurisé	

0. Résumé des corrections apportées

Avant de dérouler la procédure, voici les points de la version précédente qui ont été vérifiés contre la documentation officielle Certify The Web et corrigés :

Point	Version initiale	Correction
Port 9696	Présenté comme le port de l'API du Management Hub	C'est le port local de Certify Certificate Manager (l'app classique), utilisé par l'UI pour parler au service local (127.0.0.2:9696). Le Hub utilise un port distinct et configurable (ex. 8080 par défaut en Docker, ou tout port choisi à l'installation Windows).
Licence	Non mentionnée	Certify Certificate Manager (Community) est gratuit jusqu'à 5 certificats/serveur. Le Management Hub est inclus dans le palier « Power Pro » ou supérieur, mais utilisable en évaluation sans limite de temps.
SAN OPT-IIS-01..06 dans le certificat public	Inclus par défaut dans le SAN public, avec distribution prévue vers les 6 IIS	RETIRÉ. Confirmé par vos soins : les 6 backends utilisent déjà un certificat ADCS interne (généré et déployé par Ansible / win_certificate_store) pour leur HTTPS 443 (ainsi sur des ports dédiés uniques en par site configurés aussi en HTTPS). Aucune raison de leur ajouter un certificat public — la Phase 6 « distribution vers les 6 IIS » est donc supprimée et remplacée par une explication de l'architecture TLS bridging.
Fuite d'information via Certificate Transparency	Non traité	Tout certificat public (Let's Encrypt) est publié dans les logs CT publics (crt.sh). Exclure les FQDN internes du SAN public évite qu'ils soient découvrables publiquement — bénéfice de sécurité réel, voir Phase 6.

1. Vue d'ensemble de l'architecture cible

D'après votre fichier d'architecture :

- OPT-RP-01.optimedit.eu : reverse-proxy IIS/ARR, futur hôte du Certify Management Hub, point d'entrée public unique.
- OPT-IIS-01 à 06.optimedit.eu : 6 backends IIS internes (13 sites répartis dessus), IP privées, HTTPS interne sur SNI 443 + HTTP 80 host-header.
- 13 sites applicatifs : achat, blog, ce, client, commercial, comptabilite, direction, formation, it, juridique, paie, production, rh — chacun avec un compte de service dédié et un port applicatif interne (8060-8072).
- PKI interne ADCS (OPT-DC-01) : déjà utilisée pour sécuriser les échanges internes (WinRM, bindings internes).
- Ansible : provisionnement WinRM/Kerberos/HTTPS (port 5986) des backends, y compris le déploiement du certificat interne ADCS via `win\_certificate\_store`.

Décision confirmée : deux PKI, deux périmètres

Le certificat public (Let's Encrypt via Certify Hub / OVH DNS-01) ne couvre QUE OPT-RP-01.optimedit.eu + les 13 sous-domaines applicatifs — c'est le seul segment exposé sur Internet.

Les 6 backends OPT-IIS-01..06 gardent leur certificat interne ADCS (SAN couvrant RP + 6 backends + 13 apps si besoin), déployé comme aujourd'hui via Ansible. Ce certificat ne sert qu'au tronçon RP → backend, jamais exposé côté client public.

Ces deux certificats cohabitent sans conflit : ce sont deux connexions TLS distinctes, sur deux segments réseau différents. Voir Phase 6 pour le détail de cette architecture « TLS bridging ».

Phase 1 — Reverse-proxy ARR sur OPT-RP-01

1.1 Installation du serveur et rôles Windows

1. Installer Windows Server sur OPT-RP-01.optimedit.eu, le joindre au domaine AD optimedit.eu, lui attribuer son IP publique + IP interne, DNS A déjà en place.
2. Installer le rôle IIS avec les modules par défaut.
3. Installer Application Request Routing (ARR) et URL Rewrite (prérequis d'ARR) via Web Platform Installer ou les paquets MSI officiels Microsoft.
 - ✓ Télécharger et installer Application Request Routing (ARR) 3.0 :
<https://www.iis.net/downloads/microsoft/application-request-routing>
 - ✓ Le module URL Rewrite s'installera automatiquement avec ARR, si ce n'est pas le cas voici le lien :
<https://www.iis.net/downloads/microsoft/url-rewrite>

1.2 Arborescne physique et sites IIS

Créer les dossiers physiques et les sites pour les 13 applications, plus un site dédié pour le Hub :

```
New-Item -ItemType Directory -Path 'C:\apps_optimedit' -Force
$sites = 'achat','blog','ce','client','commercial','comptabilite','direction',
         'formation','it','juridique','paie','production','rh'
foreach ($s in $sites) {
    New-Item -ItemType Directory -Path "C:\apps_optimedit\$s" -Force
}
New-Item -ItemType Directory -Path 'C:\inetpub\HUB' -Force
```

Créer les 13 sites + le site HUB, et leurs pools d'applications dédiés :

```
Import-Module WebAdministration
foreach ($s in $sites) {
    New-WebAppPool -Name "pool_$s"
    New-Website -Name $s -PhysicalPath "C:\apps_optimedit\$s" `
        -ApplicationPool "pool_$s" -Port 80 -HostHeader "$s.optimedit.eu"
}
New-WebAppPool -Name 'pool_hub'
New-Website -Name 'HUB' -PhysicalPath 'C:\inetpub\HUB' `
    -ApplicationPool 'pool_hub' -Port 80 -HostHeader 'hub.optimedit.eu'
```

Identité des pools (svc_xxx) — précision

Lier un compte de service (svc_achat, svc_blog, ...) à l'identité d'un pool IIS n'est nécessaire QUE si l'application elle-même a besoin de ce contexte de sécurité (délégation Kerberos vers une base de données, accès à un partage réseau, SPN dédié, etc.).

Si les 13 sites sur OPT-RP-01 ne sont que des points d'entrée ARR qui relaient vers les vrais backends IIS, laissez l'identité par défaut ApplicationPoolIdentity — ce sont les pools SUR LES BACKENDS (OPT-IIS-01..06) qui doivent porter les svc_xxx, pas ceux du reverse-proxy.

1.3 Configuration de la ferme ARR

4. Dans IIS Manager, sélectionner le nœud serveur > Server Farms > Create Server Farm, nommer la ferme **Optimedit-Web-Farm**.
5. Ajouter les 6 FQDN backends comme serveurs de la ferme : OPT-IIS-01.optimedit.eu ... OPT-IIS-06.optimedit.eu.
6. Laisser IIS créer automatiquement la règle de réécriture **au niveau serveur** lorsqu'il le propose.

The screenshot shows the IIS Manager interface. On the left, the 'Server Farms' tree is expanded, showing a list of server farms. The 'Create Server Farm' dialog is open, showing the 'Add Server' tab. The 'Server address' field is empty, and the 'Add' button is highlighted. The 'Online' checkbox is checked. Below the 'Add' button, there is a table of server addresses and their status:

Server Address	Status
OPT-IIS-06.optimedit.eu	Online
OPT-IIS-05.optimedit.eu	Online
OPT-IIS-04.optimedit.eu	Online
OPT-IIS-03.optimedit.eu	Online
OPT-IIS-02.optimedit.eu	Online
OPT-IIS-01.optimedit.eu	Online

On the right, the 'Rewrite Rules' dialog is open, asking if IIS Manager should create a URL rewrite rule to route all incoming requests to this server farm automatically. The 'Oui' button is highlighted.

Below the dialog, the 'Connexions' tree is expanded, showing the 'Sites' node. The 'Sites' node is expanded, showing a list of sites. The 'ARR_Optimedit-Web-Farm_loadbalance' site is selected. The 'Réécriture d'URL' (URL Rewrite) feature is enabled for this site. The 'Rules de trafic entrant appliquées à l'adresse de l'URL demandée' (Incoming traffic rules applied to the requested URL address) table is shown:

Nom	Entrée	Correspondance	Modèle	Type d'action	URL d'action	Ne pas trai...	Type d'entr...
ARR_Optimedit-Web-Farm_loadbalance	Chemin de l'URL	Correspondances	*	Réécrire	http://Optimedit-Web-Farm/{R:0}	Vrai	Local

Below the table, the URL <http://Optimedit-Web-Farm/{R:0}> is shown, indicating the rule is auto-generated by ARR.

7. La règle **Reverse Proxy** à créer pour chaque site (configurations au niveau des sites).

Dans chaque site (les 13 + éventuellement HUB), aller dans URL Rewrite > Add Rule(s) > Reverse Proxy, cibler **Optimedit-Web-Farm** (entrer le nom de la ferme à la place de l'IP du Serveur Proxy), laisser la case cochée « Autoriser téléchargement SSL » pour ne pas obtenir un URL comme « ReverseProxyInboundRule1 {C:1}://Optimedit-Web-Farm/{R:1} ».

Règle obtenue (action de réécriture) :

```
http://Optimedit-Web-Farm/{R:1}
```

1.4 Autoriser le reverse-proxy sur chaque backend (port 80)

Script PowerShell à exécuter sur chacun des 6 backends OPT-IIS-01..06 localement pour n'autoriser que le trafic http/HTTPS entrant depuis OPT-RP-01 :

```
# À exécuter localement sur chaque OPT-IIS-0X.optimedit.eu
$rpName = 'OPT-RP-01.optimedit.eu'
$rpIP = (Resolve-DnsName $rpName -Type A -ErrorAction Stop).IPAddress

New-NetFirewallRule -DisplayName "Allow-ReverseProxy-HTTP-From-RP01" `
  -Direction Inbound -Protocol TCP -LocalPort 80 `
  -RemoteAddress $rpIP -Action Allow -Profile Domain

# Si HTTPS interne 443 (SNI) également relayé par ARR :
New-NetFirewallRule -DisplayName "Allow-ReverseProxy-HTTPS-From-RP01" `
```

```
-Direction Inbound -Protocol TCP -LocalPort 443 `
-RemoteAddress $rpIP -Action Allow -Profile Domain
```

```
Write-Output "Règles de pare-feu créées pour l'IP du reverse-proxy : $rpIP"
```

Ce script peut être exécuté avec un playbook avec le module `win_shell`/`win_powershell`, ou réécrit proprement avec le module `community.windows.win_firewall_rule` (recommandé pour l'idempotence).

Il existe aussi dans ce dépôt une version de ce script à exécuter à distance vers les backends « **1.4.1.Deploy-ReverseProxy-Firewall.ps1** », pour dédiés (8060–8072) « **1.4.1.Deploy-ReverseProxy-Firewall-PortsDedies.ps1** »

Création des entrées DNS (Sites pointent vers OPT-RP-01)

Sur le DC ou une machine d'administration AD (1.4.2.Update-DNS-OptimeditSites-RP.ps1) :

```
$zone = "optimedit.eu"
$rpIP = "192.168.3.200"
$log = "C:\Logs\Update-DNS-Sites.log"

if (!(Test-Path "C:\Logs")) { New-Item -ItemType Directory -Path "C:\Logs" -Force }

function Log {
    param([string]$msg)
    Add-Content -Path $log -Value "$(Get-Date) - $msg"
}

$sites = @(
    "achat", "blog", "ce", "client", "commercial", "comptabilite",
    "direction", "formation", "it", "juridique", "paie", "production", "rh"
)

foreach ($s in $sites) {
    $fqdn = "$s.$zone"

    Log "Traitement de $fqdn"

    # Supprimer l'entrée existante
    try {
        Remove-DnsServerResourceRecord -ZoneName $zone -RRType "A" -Name $s -Force -ErrorAction Stop
        Log "Entrée A supprimée : $fqdn"
    }
    catch {
        Log "Aucune entrée existante pour $fqdn"
    }

    # Créer la nouvelle entrée
    Add-DnsServerResourceRecordA -Name $s -ZoneName $zone -IPv4Address $rpIP
    Log "Entrée A créée : $fqdn -> $rpIP"
}

Log "Mise à jour DNS terminée."
```

Validation - étape 1.4

The screenshot shows the IIS Health Test tool interface. On the left, the 'Connexions' tree is expanded to 'Server Farms' > 'Optimedit-Web-Farm' > 'Servers'. The main pane displays the 'Health Test' configuration with the URL 'http://rh.optimedit.eu' entered. Below the configuration, a 'Verify URL Test' dialog box is open, showing a table of results for six servers, all of which passed the test.

Server Address	Result	Details
OPT-IIS-01.optimedit.eu	Pass	Pass
OPT-IIS-02.optimedit.eu	Pass	Pass
OPT-IIS-03.optimedit.eu	Pass	Pass
OPT-IIS-04.optimedit.eu	Pass	Pass
OPT-IIS-05.optimedit.eu	Pass	Pass
OPT-IIS-06.optimedit.eu	Pass	Pass

Validations avec des scripts - étape 1.4 :

Script	
1.4.3.Validation.SitesNonAccessiblesBackends.ps1	A ne pas exécuter sur le Revers Proxy (il suffit pour valider)
1.4.3.Validation.Configuration.Ferme.ARR.ps1	A exécuter sur le Revers Proxy (valider conf supplémentaires)

Exemples de résultats script

<pre>===== VALIDATION CONFIGURATION FERME ARR (PHASE 1.4) ===== --- TEST 1 : Connectivité HTTP 80 vers les backends --- OK : OPT-IIS-01.optimedit.eu (192.168.3.112) répond sur le port 80 OK : OPT-IIS-02.optimedit.eu (192.168.3.115) répond sur le port 80 OK : OPT-IIS-03.optimedit.eu (192.168.3.116) répond sur le port 80 OK : OPT-IIS-04.optimedit.eu (192.168.3.117) répond sur le port 80 OK : OPT-IIS-05.optimedit.eu (192.168.3.118) répond sur le port 80 OK : OPT-IIS-06.optimedit.eu (192.168.3.119) répond sur le port 80 --- TEST 2 : Vérification des 13 sites via ARR --- OK : achat.optimedit.eu (Status 200) OK : blog.optimedit.eu (Status 200) OK : ce.optimedit.eu (Status 200) OK : client.optimedit.eu (Status 200) OK : commercial.optimedit.eu (Status 200) OK : comptabilite.optimedit.eu (Status 200) OK : direction.optimedit.eu (Status 200) OK : formation.optimedit.eu (Status 200) OK : it.optimedit.eu (Status 200) OK : juridique.optimedit.eu (Status 200) OK : paie.optimedit.eu (Status 200) OK : production.optimedit.eu (Status 200) OK : rh.optimedit.eu (Status 200) --- TEST 3 : Santé de la ferme ARR --- OK : La ferme Optimedit-Web-Farm est présente</pre>	<pre>--- TEST 5 : Règles ReverseProxyInboundRule1 sur chaque site --- OK : Règle ReverseProxy trouvée pour achat OK : Règle ReverseProxy trouvée pour blog OK : Règle ReverseProxy trouvée pour ce OK : Règle ReverseProxy trouvée pour client OK : Règle ReverseProxy trouvée pour commercial OK : Règle ReverseProxy trouvée pour comptabilite OK : Règle ReverseProxy trouvée pour direction OK : Règle ReverseProxy trouvée pour formation OK : Règle ReverseProxy trouvée pour it OK : Règle ReverseProxy trouvée pour juridique OK : Règle ReverseProxy trouvée pour paie OK : Règle ReverseProxy trouvée pour production OK : Règle ReverseProxy trouvée pour rh --- TEST 6 : Vérification DNS (A -> OPT-RP-01) --- OK : achat.optimedit.eu -> 192.168.3.200 OK : blog.optimedit.eu -> 192.168.3.200 OK : ce.optimedit.eu -> 192.168.3.200 OK : client.optimedit.eu -> 192.168.3.200 OK : commercial.optimedit.eu -> 192.168.3.200 OK : comptabilite.optimedit.eu -> 192.168.3.200 OK : direction.optimedit.eu -> 192.168.3.200 OK : formation.optimedit.eu -> 192.168.3.200 OK : it.optimedit.eu -> 192.168.3.200 OK : juridique.optimedit.eu -> 192.168.3.200 OK : paie.optimedit.eu -> 192.168.3.200 OK : production.optimedit.eu -> 192.168.3.200 OK : rh.optimedit.eu -> 192.168.3.200</pre>
<pre>OK : rh répond depuis OPT-IIS-05.optimedit.eu (normal pour OPT-RP-01) StatusCode : 200 StatusDescription : OK Content : <h1>Bienvenue sur le site RH de OPTIMEDIT</h1> <p>Cible Inventaire Ansible : OPT-IIS-06.optimedit.eu</p> <p>Nom RA&e1 OS Windows (Fact) : OPT-IIS-06</p> RawContent : HTTP/1.1 200 OK Accept-Ranges: bytes Content-Length: 153 Content-Type: text/html Date: Wed, 29 Jul 2026 19:40:21 GMT ETag: "92f58aa9271ddd1:0" Last-Modified: Sun, 26 Jul 2026 17:53:27 GMT Serve... Forms : Headers : {[Accept-Ranges, bytes], [Content-Length, 153], [Content-Type, text/html], [Date, Wed, 29 Jul 2026 19:40:21 GMT]...} Images : {} InputFields : {} Links : {} ParsedHtml : RawContentLength : 153 OK : rh répond depuis OPT-IIS-06.optimedit.eu (normal pour OPT-RP-01) ===== VALIDATION PHASE 1.4 TERMINEE =====</pre>	

Phase 2 — Création de l'API OVH (DNS-01)

Confirmé conforme à la documentation officielle Certify The Web pour le provider « OVH DNS ».

8. Se rendre sur <https://eu.api.ovh.com/createApp/> et créer une application : Name = CertifyDNS01, Description = Certify The Web DNS-01 Automation.
9. Noter l'Application Key et l'Application Secret générés automatiquement.
10. Se rendre sur <https://eu.api.ovh.com/auth/> pour générer la Consumer Key, avec les droits suivants :

```
GET    /domain/zone/*  
POST   /domain/zone/*  
DELETE /domain/zone/*
```

11. Valider la demande (OVH peut demander une confirmation via l'espace client). Conserver précieusement les 3 valeurs : Application Key, Application Secret, Consumer Key.

Bonne pratique sécurité

Donnez une durée de validité limitée à ces credentials si possible, ou a minima documentez-les comme secret sensible (coffre-fort type Ansible Vault / KeePass / Azure Key Vault) — ils permettent de modifier toute la zone DNS optimedit.eu, pas seulement les enregistrements TXT ACME.

Phase 3 — Installation de Certify Management Hub sur OPT-RP-01

3.1 Compte de service

Créer un compte de service dédié dans l'AD (ex. svc_certify) si le Hub doit tourner sous un compte de domaine (utile pour certaines tâches de déploiement Windows nécessitant des droits réseau). Pour une installation Windows standalone du Hub, le compte Local System / Network Service par défaut est suffisant dans la majorité des cas — n'utilisez svc_certify que si vous avez des tâches de déploiement qui nécessitent explicitement une identité de domaine.

3.2 Installation

12. Télécharger et installer Certify Management Hub (édition Windows) sur OPT-RP-01.optimedit.eu.
13. Par défaut l'interface et l'API sont exposées en local — le port par défaut dépend du package d'installation choisi (8080 pour l'image Docker officielle ; un port différent, souvent proposé lors de l'installateur Windows). Vérifiez le port réellement utilisé dans le fichier de configuration du service (hubservice.json) plutôt que de supposer 8080 ou 9696.
14. Se connecter une première fois avec les identifiants par défaut (admin / changeme! ou équivalent affiché à l'installation), puis changer IMMÉDIATEMENT le mot de passe administrateur.

Correction — le port 9696

9696 est le port de l'API locale de Certify Certificate Manager (l'application desktop classique), pas celui du Hub. Ne cherchez pas à exposer 9696 publiquement : il n'a aucun rôle dans l'architecture Hub / ARR / DNS-01 décrite ici.

Le port du Hub (8080 par défaut en conteneur, ou celui choisi à l'installation Windows) doit lui aussi rester en écoute LOCALE UNIQUEMENT (127.0.0.1) — c'est ARR qui l'exposera en HTTPS sur 8443, voir Phase 5.

3.3 Ajouter le provider DNS OVH dans le Hub

15. Dans le Hub : Settings → Credentials → Add New Credential.
16. Provider : DNS Provider → OVH.
17. Renseigner Application Key, Application Secret, Consumer Key, Endpoint = ovh-eu.
18. Enregistrer.

Phase 4 — Émission du certificat SAN public

19. Dans le Hub : New Certificate.
20. Target Instance : le Hub lui-même (puisque'il tourne sur OPT-RP-01, qui est le serveur public).
21. Ajouter les SAN (14 noms — les 6 backends OPT-IIS-01..06 NE sont PAS inclus, voir Phase 6) :

```
OPT-RP-01.optimedit.eu
achat.optimedit.eu
blog.optimedit.eu
ce.optimedit.eu
client.optimedit.eu
commercial.optimedit.eu
comptabilite.optimedit.eu
direction.optimedit.eu
formation.optimedit.eu
it.optimedit.eu
juridique.optimedit.eu
paie.optimedit.eu
production.optimedit.eu
rh.optimedit.eu
```

22. Méthode de validation : DNS-01 → credential OVH créé en Phase 3.
23. Mode : un seul certificat, SAN multiples (pas de wildcard : les 13 sous-domaines seraient certes couverts par *.optimedit.eu, mais un wildcard élargit inutilement la surface de confiance et complique la CT-log — un SAN explicite reste préférable ici).
24. Lancer la demande. Le Hub crée le(s) enregistrement(s) TXT _acme-challenge via l'API OVH, attend la propagation, Let's Encrypt valide, le TXT est nettoyé automatiquement.
25. Une fois émis, le certificat est installé/disponible sur OPT-RP-01 (magasin local ou export PFX selon la tâche de déploiement configurée).

Limite Let's Encrypt à connaître

20 SAN sur un seul certificat est en dessous de la limite technique de Let's Encrypt (100 noms par certificat), donc pas de souci de ce côté. En revanche, chaque renouvellement redemande la validation DNS-01 pour les 20 noms : assurez-vous que le credential OVH reste valide dans la durée (pas de Consumer Key à expiration courte oubliée).

Phase 5 — Exposer le Hub en HTTPS via ARR (port 8443)

26. Dans IIS sur OPT-RP-01, sur le site HUB (C:\inetpub\HUB), ajouter un binding HTTPS sur le port 8443, IP = All Unassigned, certificat SSL = le certificat SAN émis en Phase 4 (il couvre OPT-RP-01.optimedit.eu), SNI activé.
27. Ajouter une règle de reverse-proxy sur ce site HUB : Inbound Rule pointant vers le service local du Hub.

```
<!-- web.config du site HUB -->
<rule name="ReverseProxyToHub" stopProcessing="true">
  <match url="(.*)" />
```

```
<action type="Rewrite" url="http://localhost:8080/{R:1}" />
</rule>
<!-- Remplacez 8080 par le port réel du Hub si différent -->
```

28. Créer la règle de pare-feu Windows locale sur OPT-RP-01 pour n'autoriser 8443 que depuis les postes d'administration autorisés (LAN) :

```
New-NetFirewallRule -DisplayName 'HUB-HTTPS-8443-LAN' `
  -Direction Inbound -Protocol TCP -LocalPort 8443 `
  -RemoteAddress 192.168.0.0/16 -Action Allow -Profile Domain
```

29. Tester :

```
Test-NetConnection localhost -Port 8443
```

Ne pas exposer le Hub publiquement

La documentation officielle est explicite : le Hub ne doit pas être exposé directement sur Internet sans conception et revue de sécurité dédiées. Gardez 8443 restreint au LAN/VPN d'administration, jamais ouvert sur l'IP publique de OPT-RP-01.

Phase 6 — Architecture TLS bridging : deux PKI, aucun conflit

Ce chapitre remplace la distribution du certificat public vers les 6 backends, désormais inutile : ceux-ci gardent leur certificat interne ADCS existant, généré et déployé par Ansible (win_certificate_store), et n'ont donc rien à recevoir du Hub.

6.1 Le schéma retenu

```
Client Internet
| TLS public (certificat SAN Let's Encrypt : RP + 13 sous-domaines)
▼
OPT-RP-01 (ARR — terminaison TLS publique)
| TLS interne (certificat SAN ADCS : RP + 6 backends + 13 apps)
▼
OPT-IIS-01..06 (backends, HTTPS interne SNI 443)
```

C'est le patron classique « TLS bridging » (terminaison + ré-chiffrement) : ARR déchiffre la session cliente avec le certificat public, puis ouvre une seconde session TLS vers le backend avec le certificat ADCS. Ce sont deux poignées de main TLS totalement indépendantes.

6.2 Pourquoi il n'y a aucun conflit

- Chaque binding IIS (IP:port + hôte SNI) est associé à un seul magasin de certificats à un instant donné — les deux certificats coexistent simplement dans des bindings différents, sur des machines différentes.
- Le client final ne voit jamais le certificat ADCS : il s'arrête à OPT-RP-01. Aucun navigateur externe n'a donc besoin de faire confiance à votre CA d'entreprise.
- Les backends, eux, font déjà confiance à la CA ADCS (ils sont joints au domaine optimedit.eu) : rien à changer côté validation de chaîne.
- Dans les paramètres de la ferme ARR (Server Farm > Servers > Advanced Settings), vous pouvez activer la vérification stricte du certificat backend si vous voulez qu'ARR valide explicitement la chaîne ADCS plutôt que de l'ignorer — recommandé en production.

6.3 Bénéfice de sécurité : Certificate Transparency

Pourquoi exclure les backends du SAN public est une bonne pratique

Tout certificat émis par une autorité publique reconnue (Let's Encrypt inclus) est obligatoirement publié dans les logs Certificate Transparency (ex. crt.sh) — c'est une exigence de l'écosystème CA/Browser Forum, pas une option désactivable.

Si OPT-IIS-01..06.optimedit.eu figuraient dans ce certificat, n'importe qui pourrait retrouver ces noms en interrogeant crt.sh sur « optimedit.eu », même si ces serveurs ne sont jamais exposés sur Internet — c'est une technique de reconnaissance/OSINT courante pour cartographier une infrastructure interne.

En les gardant exclusivement sur votre certificat ADCS interne (CA privée, jamais publiée dans les logs CT publics), vous évitez cette fuite d'information sur votre convention de nommage et le nombre réel de backends.

6.4 Ce qu'il reste à vérifier sur les backends

- Le certificat ADCS actuel couvre-t-il bien les 6 FQDN + éventuellement OPT-RP-01 ? Sinon, régénérer un template ADCS avec le SAN correct et redéployer via le playbook Ansible existant.
- Renouvellement du certificat ADCS : vérifiez sa durée de validité et l'automatisation existante (le playbook Ansible qui gère win_certificate_store doit tourner avant expiration, indépendamment du cycle de renouvellement 90 jours de Let's Encrypt sur le RP).
- WinRM (port 5986) : s'il utilise le même certificat ADCS, aucune action ; s'il doit être validé par une chaîne publique pour un usage externe précis, réévaluez au cas par cas — ce n'est pas une raison suffisante pour republier les FQDN internes dans un certificat public.

6.5 TLS Bridging vs TLS End-to-End (Passthrough)

Pour resituer le choix fait en 6.1, voici le comparatif entre les deux grands modèles de terminaison TLS dans un reverse-proxy :

Critère	TLS Bridging	TLS End-to-End (Strict / Passthrough)
Sessions TLS	Deux sessions distinctes (Client → Proxy, puis Proxy → Serveur)	Une seule session continue (Client → Serveur)
Déchiffrement intermédiaire	Oui, au niveau du reverse proxy	Non, le proxy est aveugle au contenu
Inspection HTTP / WAF	Possible (le proxy lit le trafic en clair)	Impossible (le trafic reste chiffré de bout en bout)
Gestion des certificats	Un certificat sur le proxy (public), un autre sur le serveur (ADCS)	Un seul certificat, porté par le serveur final — et il doit alors être approuvé directement par le client

Pourquoi IIS/ARR est structurellement en mode Bridging

Avec la stack utilisée ici (IIS + ARR + règles URL Rewrite de type Reverse Proxy), l'architecture est en mode Bridging par construction, pas par choix de configuration. ARR fonctionne au niveau HTTP : il doit déchiffrer pour lire le Host header et réécrire l'URL vers la ferme de backends (<http://Optimedit-Web-Farm/{R:1}>).

Un vrai passthrough SNI (le proxy route uniquement sur le nom de domaine, sans jamais toucher au contenu HTTP) nécessite un proxy de couche 4 : HAProxy en mode tcp, le module stream de nginx, un load-balancer L4 (Azure/AWS), ou netsh interface portproxy côté Windows. IIS/ARR n'a pas cette capacité nativement.

Conséquence pratique : le Bridging retenu en Phase 6 n'est pas seulement recommandé pour ce projet, c'est la seule option compatible avec l'architecture IIS ARR telle qu'elle est construite ici.

Phase 7 — Piloter le Hub via son API (Postman)

Le Hub expose une API REST protégée, utilisée notamment pour la jonction d'instances (Client ID / Client Secret obtenus via Settings → Security → API Access dans l'interface du Hub).

Point de prudence — chemins d'API non vérifiés

Je n'ai pas pu confirmer, depuis la documentation publique consultée, les chemins exacts des endpoints REST (login, /certificates, /instances, etc.) ni le format précis du flux d'authentification (OAuth2 client_credentials vs jeton propriétaire). Plutôt que de vous donner des URL inventées qui ne fonctionneraient pas, voici la marche à suivre fiable :

30. Dans le Hub : Settings → Security → API Access. Cette page documente (ou permet de générer/exporter) la référence des endpoints publics disponibles pour votre version exacte du Hub — les endpoints évoluent entre versions (le changelog officiel mentionne une réorganisation des endpoints publics/internes).
31. Créer une clé API (Client ID + Client Secret) dédiée à Postman, distincte de la clé d'administration principale (principe de moindre privilège).
32. Dans Postman, créer un environnement avec les variables suivantes, à compléter depuis la page API Access :

```
hub_base_url    = https://OPT-RP-01.optimedit.eu:8443    (ou l'URL interne du Hub)
client_id       = <à copier depuis Settings > Security > API Access>
client_secret   = <idem>
access_token    = (rempli automatiquement par le script ci-dessous)
```

33. Dans l'onglet Authorization de la requête de login (dont le chemin exact est à confirmer dans la page API Access de votre version), utiliser Basic Auth ou un corps client_credentials selon ce que documente le Hub, puis dans l'onglet Tests de cette requête, ajouter un script pour capturer le jeton et le stocker dans la variable d'environnement :

```
// Postman > onglet Tests de la requête de login
const data = pm.response.json();
pm.environment.set("access_token", data.access_token || data.token);
```

34. Pour toutes les requêtes suivantes (liste des instances, liste des certificats, etc.), utiliser Authorization → Bearer Token → {{access_token}}.

Recommandation

Avant de construire une collection Postman complète, ouvrez une fois la page Settings → Security → API Access dans le Hub : elle liste (selon la version) soit une documentation interactive, soit un lien vers un swagger/OpenAPI exporté. Copiez ces chemins réels dans Postman plutôt que de vous fier à des exemples génériques — cela évite des heures de débogage sur des routes qui n'existent pas dans votre version.

Phase 8 — Validation finale

#	Contrôle	Résultat attendu
1	Test-NetConnection OPT-RP-01 -Port 443	Succès, certificat SAN présenté avec SNI
2	Test-NetConnection OPT-RP-01 -Port 8443 (depuis LAN)	Succès, UI Hub accessible en HTTPS
3	Test-NetConnection OPT-RP-01 -Port 8443 (depuis Internet)	Échec attendu (bloqué au pare-feu — le Hub n'est pas public)

#	Contrôle	Résultat attendu
4	Renouvellement automatique (staging puis production)	TXT créé/supprimé automatiquement dans la zone OVH, aucune intervention manuelle
5	Binding HTTPS sur chacun des 13 sites via ARR	Chaque sous-domaine répond avec le certificat SAN public, sans erreur de nom
6	Backends OPT-IIS-01..06 : certificat ADCS interne à jour	Renouvellement et bindings gérés par le playbook Ansible existant, indépendant du cycle Let's Encrypt du RP
7	Pare-feu backends : seul OPT-RP-01 autorisé sur 80/443	Toute autre source refusée
8	Recherche crt.sh « optimedit.eu »	Seuls OPT-RP-01 et les 13 sous-domaines apparaissent — aucune trace des 6 backends internes

Sources consultées

docs.certifytheweb.com (Hub, Background Service, DNS Providers > OVH, Get Started with Hub, Certify Certificate Manager, Certify Management Agent, DNS-01 Validation, Request Your First Certificate, Release Notes).

certifytheweb.com (page produit, Features, Register/Licensing), hub.docker.com/r/certifytheweb/management-hub, [forum community.certifytheweb.com](https://forum.community.certifytheweb.com).

Ces éléments ont été vérifiés le 25 juillet 2026 ; en cas de doute sur une version précise du produit, recroisez avec la documentation en ligne au moment de l'implémentation.